Chuleta Hack&Win: Comandos, Metodología y Ejercicios

Lleva esto impreso o en el móvil el día de la Hack&Win. No hace falta memorizar nada: la idea es que cuando te encuentres un reto sepas qué herramienta probar y qué comando lanzar primero. Está organizado en tres partes: comandos por categoría, la metodología Plan-Do-Check para no perderte en un reto, y ejercicios para practicar antes del evento.

1. Chuleta de comandos

Reconocimiento y tráfico

Nmap — escaneo de puertos y servicios

```
nmap -sV -sC -p- <IP>
```

- `-sV`: detecta versión del servicio en cada puerto
- `-sC`: lanza scripts básicos de reconocimiento (detecta vulnerabilidades típicas)
- `-p-`: escanea los 65535 puertos (por defecto solo mira los 1000 más comunes)
- `-sS`: escaneo "sigiloso" SYN, manda el paquete de sincronización sin completar el handshake — rápido y deja menos rastro
- `-A`: modo agresivo, combina detección de SO, versión, scripts y traceroute (muy ruidoso)
- `-oN salida.txt`: guarda el resultado en un archivo

Gobuster — fuerza bruta de directorios y archivos web

```
gobuster dir -u http://objetivo -w /ruta/diccionario.txt -x php,txt,html
```

- `dir`: modo búsqueda de directorios (también existe `dns` para subdominios)
- `-u`: URL objetivo
- `-w`: wordlist/diccionario a usar
- `-x`: extensiones de archivo a probar (php, txt, html...)
- `-t 50`: número de hilos en paralelo (más rápido, más ruido)

Wireshark — análisis de tráfico capturado

- Filtro por protocolo: `http`, `dns`, `ftp`, `tcp.port == 80`
- Filtro por texto/cadena: `frame contains "password"`

- Seguir una conversación completa: clic derecho → *Follow* → *TCP Stream* (muy útil para ver login en claro)
- `ip.addr == X.X.X.X`: filtra todo el tráfico de/hacia una IP concreta

Contraseñas

John the Ripper — crackeo de hashes por fuerza bruta/diccionario

```
john --wordlist=/ruta/diccionario.txt hash.txt
john --show hash.txt
```

- `--wordlist=`: ataque de diccionario con la lista indicada
- (sin `--wordlist`): ataque de fuerza bruta incremental, detecta el tipo de hash solo
- `--format=<tipo>`: fuerza un formato de hash concreto si no lo detecta bien
- `--show`: muestra las contraseñas ya crackeadas

Hydra — fuerza bruta de login en servicios (web, ssh, ftp...)

```
hydra -l usuario -P /ruta/diccionario.txt ssh://IP
hydra -L usuarios.txt -P contraseñas.txt objetivo http-post-form
"/login:user=^USER^&pass=^PASS^:F=incorrect"
```

- `-l`: un único usuario fijo
- `-L`: lista de usuarios a probar
- `-P`: lista de contraseñas (diccionario)
- `-t 4`: hilos en paralelo
- último parámetro: protocolo/servicio (`ssh://`, `ftp://`, `http-post-form`...)

Forense y esteganografía

ExifTool — leer/editar metadatos de archivos multimedia

```
exiftool imagen.jpg
exiftool -GPS* imagen.jpg
exiftool -all= imagen.jpg
```

- (sin opciones): lista todos los metadatos del archivo
- `-GPS*`: filtra solo los metadatos de localización
- `-all=`: elimina todos los metadatos
- `-Comment="texto"`: añade o edita un campo concreto

Steghide — ocultar/extraer datos dentro de imágenes

```
steghide extract -sf imagen.jpg
steghide embed -cf imagen.jpg -ef secreto.txt
```

- `extract -sf`: extrae lo que haya oculto en el archivo indicado (pedirá contraseña si tiene)
- `embed -cf ... -ef ...`: oculta el archivo `-ef` dentro de la imagen `-cf`
- `-p "clave"`: indica la contraseña directamente sin que la pida
- Revisa siempre el final y zonas intermedias del archivo, no solo lo evidente

Web

OWASP ZAP — proxy interceptor y escáner de vulnerabilidades web

- Configura el navegador para pasar por el proxy de ZAP (normalmente `127.0.0.1:8080`)
- *Spider*: rastrea automáticamente todas las URLs de la web
- *Active Scan*: lanza ataques automáticos conocidos (XSS, SQLi...) sobre lo rastreado
- Pestaña *Break*: intercepta y edita las peticiones antes de que lleguen al servidor

Tokens

JWT.io — decodificar y manipular tokens JWT

- Pega el token en la web y verás *Header*, *Payload* y *Signature* por separado en claro
- Si el servidor no valida bien la firma, se puede modificar el payload (p. ej. `"role":"admin"`) y volver a generar el token

Post-explotación

GTFOBins (web, no comando) — buscar cómo escalar privilegios en Linux a partir de un binario con permisos especiales (SUID) o que puedas ejecutar como root en un `sudo -l`

HackTricks (web, no comando) — buscar paso a paso cualquier tipo de reto; es la referencia para los retos físicos (dron, tanque)

2. Manual Plan-Do-Check para cada reto

Cada vez que te atasques en un reto, vuelve a este esquema en lugar de probar herramientas al azar.

PLAN — entender y clasificar

1. Lee el enunciado dos veces y anota qué te dan (IP, archivo, URL, pregunta...) y qué piden exactamente (una flag, una contraseña, un acceso...).
2. Clasifica el vector: ¿web, cripto, forense, esteganografía, codificación, binarios, red?
3. Según el vector, decide con qué herramienta vas a empezar a mirar (usa la chuleta de arriba).
4. Si no tienes ni idea del vector, pregúntate: ¿hay una IP o URL? → red/web. ¿Hay un archivo? → forense/esteganografía/binario. ¿Hay texto raro? → codificación/cripto.

DO — ejecutar y explorar

5. Lanza el reconocimiento básico primero (Nmap si hay IP, ExifTool si hay archivo, mirar el código fuente si hay web).
6. Anota TODO lo que vayas encontrando (puertos abiertos, tecnologías, strings raros) aunque no sepas aún para qué sirve — luego puede encajar.
7. Si un camino no avanza en unos minutos, no te obsesiones: prueba otro vector o busca en HackTricks ese tipo de reto concreto.
8. Usa la IA para que te explique un error, un concepto o te sugiera el siguiente paso, pero no te fíes a ciegas — puede llevarte por un camino equivocado, contrástalo.

CHECK — verificar y documentar

9. Antes de dar la flag por buena, revisa el formato que piden (muchos CTF usan algo como `flag{...}`).
10. Apunta en un documento rápido (aunque sea a mano) qué herramienta y qué comando te funcionó — te ahorra tiempo si vuelve a salir algo parecido en otro reto.
11. Si no sale, vuelve al PLAN: ¿has clasificado bien el vector? ¿te has dejado algo oculto (metadatos, parte final del archivo, un puerto que no revisaste)?

Reto especial: el dron

Es el reto "tocho" del evento. Según lo que os contaron, la vulnerabilidad se saca apoyándote en HackTricks. Trátalo igual que cualquier otro reto: identifica primero cómo se comunica (Wi-Fi, radio, Bluetooth), captura ese tráfico con Wireshark o un sniffer, y busca en HackTricks la sección específica de seguridad en drones/IoT antes de improvisar.

3. Ejercicios para practicar antes del evento

Todos con plataformas legales de entrenamiento, para no meterte en problemas. Ve de menos a más.

Nivel 1 — soltura con las herramientas

- [ ] Instala Nmap y escanea tu propia red local (`nmap -sV 192.168.1.0/24`) para ver qué dispositivos y puertos encuentras.
- [ ] Descarga una foto con metadatos (cualquier foto hecha con el móvil) y sácale toda la info con ExifTool.
- [ ] Oculta un `.txt` dentro de una imagen con Steghide y luego extráelo, para entender ambos sentidos.
- [ ] Coge un hash de contraseña sencillo (genera uno con `md5sum` de una palabra corta) e intenta crackearlo con John the Ripper usando un diccionario pequeño.

Nivel 2 — web

- [ ] Monta `demo.owasp-juice.shop` con Docker y resuelve al menos 3 retos del propio juego (tiene pistas integradas).
- [ ] Haz un `gobuster dir` contra esa misma app y compara lo que encuentra con lo que ya conocías navegando a mano.
- [ ] Intercepta una petición de login con OWASP ZAP y mira qué datos viajan en claro.
- [ ] Genera un JWT de ejemplo en jwt.io, cambia un campo del payload y observa cómo cambia (o no) la firma.

Nivel 3 — tráfico y red

- [ ] Captura tráfico de tu propio navegador con Wireshark mientras visitas una web sin HTTPS (hay demos públicas) y sigue el "TCP Stream" para ver qué se transmite.
- [ ] Filtra esa misma captura por `http` y por una cadena de texto conocida.

Nivel 4 — CTF completo

- [ ] Regístrate en **picoCTF** (gratis, pensado para principiantes) y resuelve 2-3 retos de las categorías Web, Forensics y Cryptography.
- [ ] Elige un reto de TryHackMe de nivel "easy" en la ruta de introducción a CTF y resuélvelo aplicando el esquema Plan-Do-Check de la sección anterior.

Nivel 5 — el reto del dron

- [ ] Busca en HackTricks la sección sobre pentesting de drones o dispositivos IoT/radio y léela por encima para tener vocabulario y conceptos antes del evento (no hace falta practicarlo en físico).
- [ ] Repasa conceptos básicos de Wi-Fi y protocolos de radio/telemetría de drones (MAVLink es un término que te puede sonar en HackTricks).